

TASK 04: BROKEN ACCESS CONTROL & IDOR (PORTSWIGGER LABS)

Broken Access Control is ranked #1 in the OWASP Top 10 (2021) and represents failures in enforcing proper restrictions on what authenticated users are allowed to do. I completed three PortSwigger Web Security Academy labs covering different Broken Access Control scenarios: exploiting robots.txt disclosure, extracting admin URL from JavaScript source, and escalating privileges via cookie manipulation.

Lab 1: Unprotected Admin Functionality via robots.txt

In the first lab, I navigated to the /robots.txt file of the target application. The robots.txt file is intended to instruct search engine crawlers which pages to avoid indexing, but developers often inadvertently list sensitive paths in Disallow entries — revealing hidden administrative paths. The robots.txt file disclosed a Disallow entry for /administrator-panel. I directly navigated to this URL and accessed the admin panel without any authentication challenge, demonstrating that 'security by obscurity' is not access control. I then deleted the user 'carlos' to complete the lab objective.

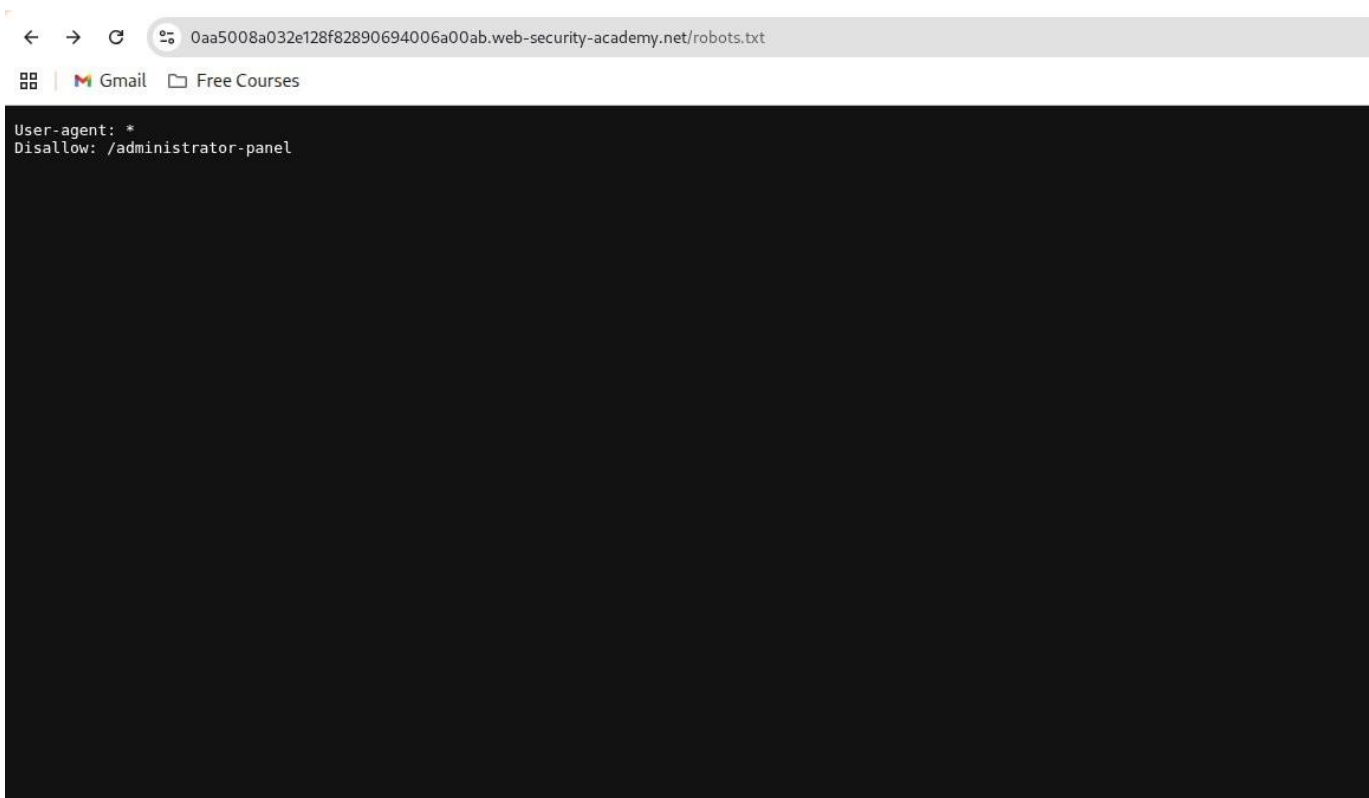


Figure 14 – robots.txt file revealing 'Disallow: /administrator-panel'. This file was publicly accessible and disclosed the exact path to the administrative interface without any authentication requirement.

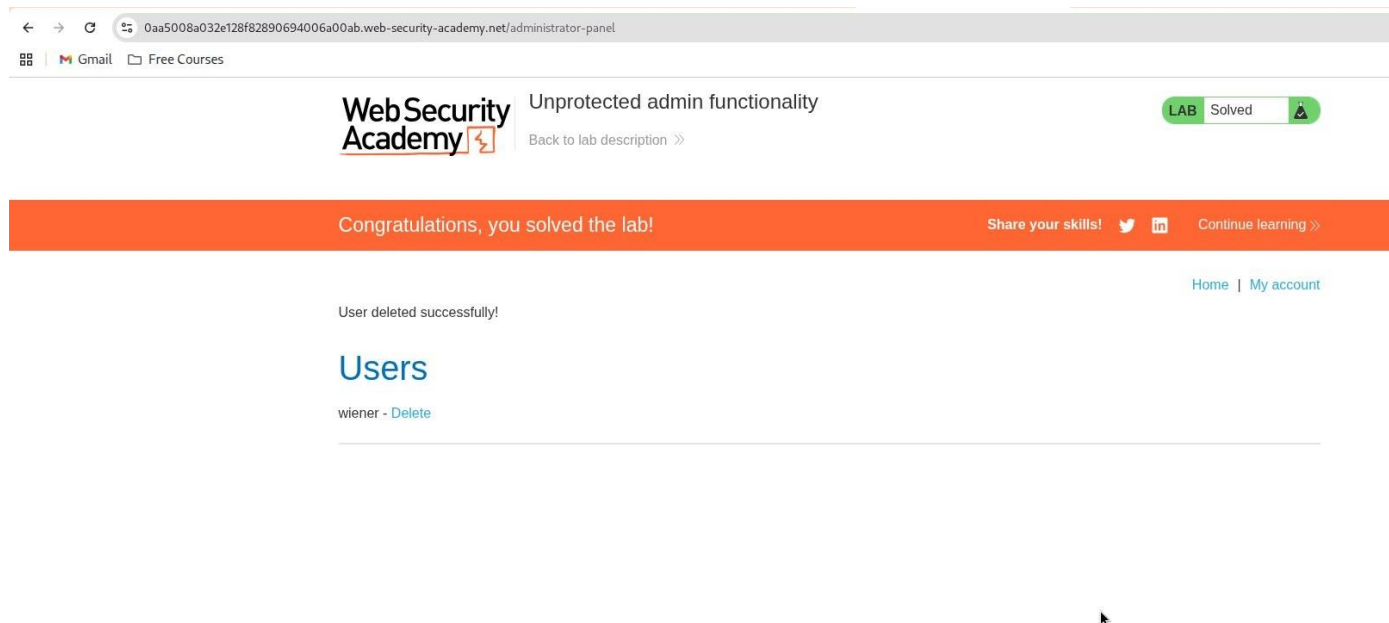


Figure 15 – Direct access to /administrator-panel achieved by simply navigating to the URL disclosed in robots.txt. The admin panel displays the user list (wiener, carlos) with Delete options. Lab solved confirmation banner visible. The user 'carlos' was deleted to complete the objective.

Lab 2: Unprotected Admin Functionality with Unpredictable URL (JavaScript Source)

The second lab had a more sophisticated protection — the admin panel URL was not listed in robots.txt and was not guessable. However, I inspected the application's JavaScript source code by viewing the page source. The script contained a conditional block checking if the current user isAdmin, and if so, dynamically adding an 'Admin panel' link with the hardcoded path /admin-98bu0h. This is a common developer mistake: hiding sensitive paths in client-side JavaScript provides no real security because any user can view the page source. I navigated directly to this URL and accessed the admin panel.

```

<script>
var isAdmin = false;
if (isAdmin) {
  var topLinksTag = document.getElementsByClassName("top-links")[0];
  var adminPanelTag = document.createElement('a');
  adminPanelTag.setAttribute('href', '/admin-98bu0h');
  adminPanelTag.innerText = 'Admin panel';
  topLinksTag.append(adminPanelTag);
  var pTag = document.createElement('p');
  pTag.innerText = '|';
  topLinksTag.appendChild(pTag);
}
</script>

<a href="/my-account">My account</a><p>|</p>
</section>
</body>

```

Figure 16 – JavaScript source code revealing the admin panel path /admin-98bu0h. The script checks 'var isAdmin = false' and conditionally displays the admin link — but the path is hardcoded in the client-side code and visible to all users.

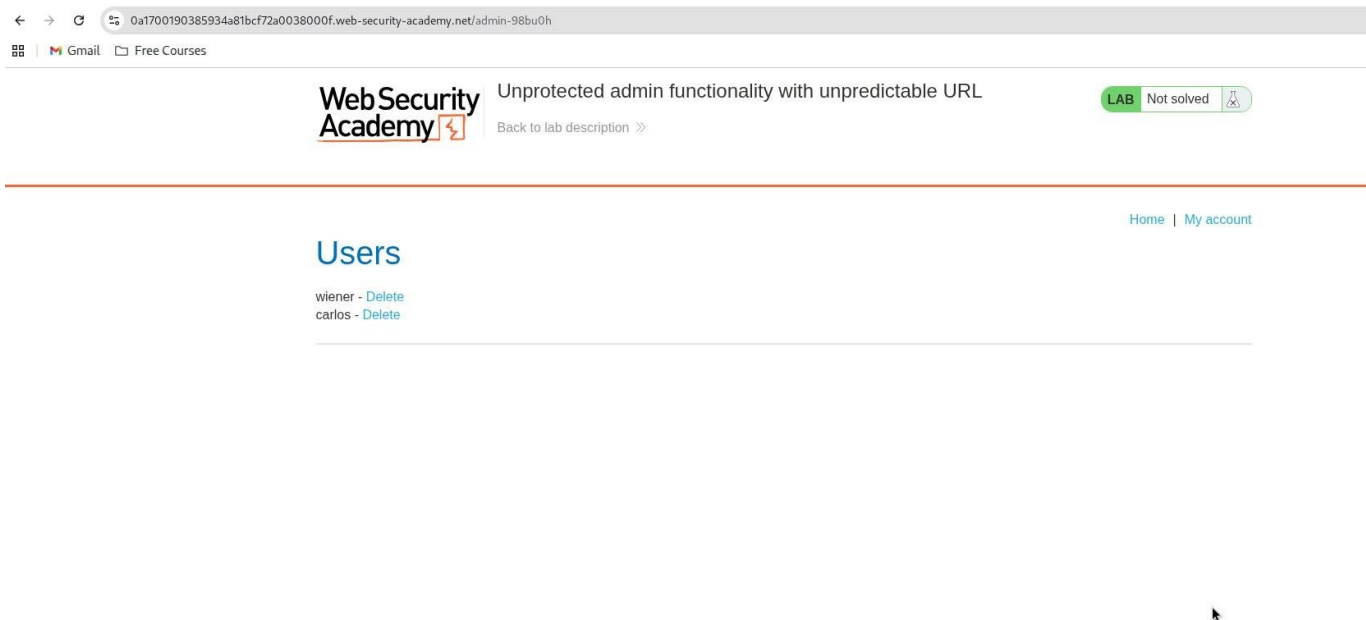


Figure 17 – Admin panel at `/admin-98bu0h` accessed directly by navigating to the URL discovered in the JavaScript source. The panel shows users 'wiener' and 'carlos' with Delete options, confirming full unauthorized administrative access.

Lab 3: Privilege Escalation via User-Controlled Cookie Parameter

The third lab demonstrated how trust in client-side parameters enables privilege escalation. After logging in as a standard user, I used the browser's Developer Tools Application tab to inspect the session cookies. I discovered an 'Admin' cookie with a value of 'false'. By modifying this cookie value to 'true' using the DevTools cookie editor, I elevated my session to administrative privileges. On the next request, the server trusted this client-side value and granted full admin access — revealing the user management panel and allowing me to delete the user 'carlos' to solve the lab.

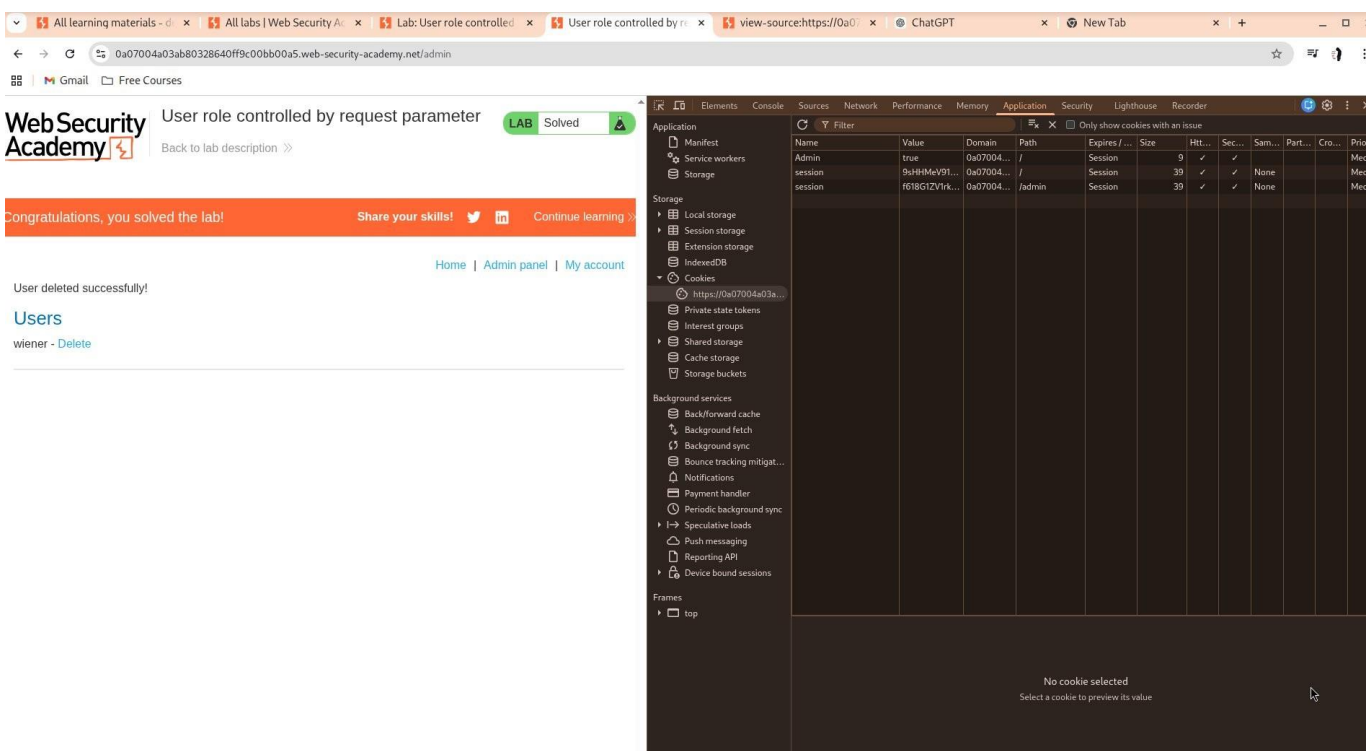


Figure 18 – Browser Developer Tools Application tab showing the discovered 'Admin' cookie set to 'true' after modification. The admin panel now shows the user list with 'User deleted successfully!' confirmation and the 'Congratulations, you solved the lab!' banner.